

# Aetheris Therapeutics S.p.A. — Case Study & Interviews

Profilo organizzativo, contesto d'infrastruttura ed evidenze raccolte durante i colloqui d'audit con gli stakeholder chiave (IT, Security, Governance, HR, Legal).

 **Contesto dell'Assessment:** Questo documento raccoglie la trascrizione e la sintesi analitica delle interviste condotte in fase di rilevazione iniziale sul campo. Le evidenze raccolte costituiscono la base primaria per l'assegnazione dei punteggi d'audit (PASS/FAIL) nel report di Gap Analysis NIST CSF e per il perimetro SGSI ISO/IEC 27001:2022.

## 1. Profilo Aziendale e Architettura dell'Infrastruttura

### Aetheris Therapeutics S.p.A. — Panoramica Strategica

**Settore:** Biotecnologico / Farmaceutico

**Dipendenti:** ~250 dipendenti (inclusi ricercatori)

**Asset Critici:** Brevetti, Formule di ricerca, Dati clinici (PII)

**Infrastruttura:** Ibrida (On-Premise + Azure / Office 365)

L'azienda sviluppa farmaci oncologici e terapie avanzate. La protezione della proprietà intellettuale (IP) e il rispetto dei requisiti di riservatezza sui dati sanitari (GDPR) rappresentano le priorità assolute per la continuità del business e per la conformità legale.

## 2. Sintesi dei Colloqui d'Audit con gli Stakeholder

### Intervista 01 — IT Director & Systems Administrator

**Q: Come gestite il censimento e l'inventario degli asset informatici aziendali?**

R: Gestiamo i laptop tramite un foglio Excel aggiornato manualmente. Non abbiamo un CMDB o un agente automatico per scansionare il software non autorizzato. La rete è segmentata con VLAN e protetta da firewall Palo Alto Next-Gen.

**Q: Quali sono i controlli di sicurezza attivi sugli accessi remoti e le identità?**

R: Utilizziamo Active Directory per la gestione degli utenti. L'accesso da remoto avviene tramite VPN, ma non abbiamo ancora attivato l'autenticazione a due fattori (MFA) per tutti gli utenti. Gli account Admin sono condivisi tra alcuni sistemisti senior.

**Q: Come vengono gestiti i salvataggi e il Disaster Recovery?**

R: Eseguiamo backup regolari dei server critici e conduciamo test di Disaster Recovery annuali. Tuttavia, i backup sono collegati alla rete principale e non disponiamo di una retention policy isolata (AirGap) contro attacchi ransomware estesi.

### Intervista 02 — Cybersecurity Analyst

**Q: Quali strumenti utilizzate per il monitoraggio continuativo e la detection delle minacce?**

R: Ci affidiamo a Microsoft Defender installato sui client. Non disponiamo di un SIEM per aggregare i log, né di una copertura SOC 24/7 o di una soluzione EDR centralizzata. Le anomalie vengono gestite in modalità reattiva e "ad-hoc".

**Q: Avete un piano formalizzato di Incident Response (IRP) e test di simulazione?**

R: Non esiste un documento scritto di Incident Response o procedure di escalation definite per il Board. Gestiamo gli eventi man mano che si presentano e non vengono condotte simulazioni d'attacco o tabletop exercises.

### Intervista 03 — Legal, Compliance & HR Manager

#### Q: Qual è lo stato delle policy di Data Governance, GDPR e della formazione del personale?

R: Manca un registro ufficiale dei trattamenti dei dati e una policy formale di classificazione delle informazioni. La formazione sulla sicurezza è limitata a un breve modulo d'ingresso per i neoassunti, senza corsi di aggiornamento o simulazioni di phishing.

#### Q: Come vengono gestiti i contratti con i fornitori e le terze parti (TPRM)?

R: I contratti di fornitura e i servizi SaaS esterni vengono valutati dai dipartimenti Finance e Legal esclusivamente dal punto di vista commerciale e contrattuale, senza formalizzare requisiti d'audit o clausole di sicurezza informatica.